

08 Mass Assignment

Mass Assignment is a security vulnerability which arises when an application takes in all the data supplied by the user and assigns it directly to the fields of internal objects without verifying which fields should be editable.

They take advantage of this by including concealed parameters, for example by making themselves administrators or by altering account balances, in order to obtain unauthorized privileges or to manipulate the data. This kind of vulnerability occurs frequently in APIs and web frameworks which support automatic data binding.

It can be prevented by allowlisting the permitted fields, by using separate input models, by marking the sensitive properties as read-only, and by strictly validating all the incoming requests.